CAPÍTULO 10

AUDITORÍA DE LA DIRECCIÓN

Juan Miguel Ramos Escobosa

10.1. INTRODUCCIÓN

Siempre se ha dicho que una organización es un reflejo de las características de su dirección. Los modos y maneras de actuar de aquélla están influenciados por la filosofía y la personalidad de la segunda.

Obviamente, los departamentos informáticos no son una excepción. Aunque puede argumentarse con razón, que, a su vez, estos departamentos están integrados en organizaciones mayores y que, por tanto, son destinatarios de un sinfín de estímulos de las mismas, qué duda cabe de que, dado el ámbito tecnológico tan particular de la informática, la principal influencia que dichos departamentos reciben viene inducida desde la propia dirección de informática. En cualquier caso, es en lo que se centra este capítulo: en la auditoría de la Dirección entendida como *gestión* (en el resto del capítulo se intercambiarán los dos términos) de la Informática.

Las enormes sumas que las empresas dedican a las tecnologías de la información en un crecimiento del que no se vislumbra el final y la absoluta dependencia de las mismas al uso correcto de dicha tecnología hacen muy necesaria una evaluación independiente de la función que la gestiona. Ello constituye, de hecho, la razón principal de este libro. La dirección de informática no debe quedar fuera: es una pieza clave del engranaje.

Sin entrar en discusiones profundas sobre el alcance y significado detrás del verbo *dirigir* (no es el objetivo de este libro y existen multitud de plumas más preparadas que la mía para disertar adecuadamente sobre este apartado), de una

manera general, se podría decir que algunas de las actividades básicas de todo proceso de dirección son:

- Planificar
- Organizar
- Coordinar
- Controlar

10.2. PLANIFICAR

En grandes líneas, se trata de prever la utilización de las tecnologías de la información en la empresa. Existen varios tipos de planes informáticos. El principal, y origen de todos los demás, lo constituye el Plan Estratégico de Sistemas de Información.

10.2.1. Plan Estratégico de Sistemas de Información

Es el marco básico de actuación de los Sistemas de Información en la empresa. Debe asegurar el alineamiento de los mismos con los objetivos de la propia empresa.

Desgraciadamente, la transformación de los objetivos de la empresa en objetivos informáticos no es siempre una tarea fácil. Mucho se ha escrito sobre el contenido y las ventajas e inconvenientes de las diversas metodologías de realización de este tipo de planes. No se trata en estos breves apuntes de terciar en dicha polémica. El lector encontrará abundante bibliografía sobre la materia. El auditor deberá evaluar si tales metodologías se están utilizando y/o pueden ser de utilidad para su empresa.

Estrictamente hablando, estos planes no son responsabilidad exclusiva de la Dirección de Informática. Su aprobación final probablemente incumbe a otros estamentos de la empresa: Comité de Informática (ver más abajo) e incluso en último término de la Dirección General. Sin embargo, la Dirección de Informática debe ser el permanente impulsor de una planificación de Sistemas de Información adecuada y a tiempo.

Aunque se suele definir la vigencia de un plan estratégico como de 3 a 5 años, de hecho tal plazo es muy dependiente del entorno en el que se mueve la empresa. Hay muchos factores que influyen: la cultura de la propia empresa, el sector de actividad, es decir, si la empresa se encuentra en un sector en el que el uso adecuado de la tecnología informática es un factor estratégico –el sector financiero, por ejemplo–, las acciones de la competencia, etc. Cada empresa tiene su equilibrio natural y el auditor deberá evaluar si los plazos en uso en su empresa son los adecuados.

En cualquier caso, independientemente de la metodología, los plazos y las acciones concretas llevadas a cabo, debe existir un proceso, con participación activa de los usuarios, que regularmente elabore planes estratégicos de Sistemas de Información a largo plazo, cualquiera que sea ese *largo,* y el auditor deberá evaluar su adecuación.

Guía de auditoría

El auditor deberá examinar el proceso de planificación de sistemas de información y evaluar si razonablemente se cumplen los objetivos para el mismo. Entre otros aspectos, deberá evaluar si:

- Durante el proceso de planificación se presta adecuada atención al plan estratégico de la empresa, se establecen mecanismos de sincronización entre sus grandes hitos y los proyectos informáticos asociados y se tienen en cuenta aspectos como cambios organizativos, entorno legislativo, evolución tecnológica, organización informática, recursos, etc., y sus impactos están adecuadamente recogidos en el Plan Estratégico de Sistemas de Información. Igualmente, el auditor deberá evaluar si se presta adecuada consideración a nuevas tecnologías informáticas, siempre desde el punto de vista de su contribución a los fines de la empresa y no como experimentación tecnológica.
- Las tareas y actividades presentes en el Plan tienen la correspondiente y adecuada asignación de recursos para poder llevarlas a cabo. Asimismo, si tienen plazos de consecución realistas en función de la situación actual de la empresa, de la organización informática, del estado de la tecnología, etc.

Entre las acciones a realizar, se pueden describir:

- Lectura de actas de sesiones del Comité de Informática dedicadas a la planificación estratégica.
- Identificación y lectura de los documentos intermedios prescritos por la metodología de planificación.
- Lectura y comprensión detallada del Plan e identificación de las consideraciones incluidas en el mismo sobre los objetivos empresariales, cambios organizativos, evolución tecnológica, plazos y niveles de recursos, etc.
- Realización de entrevistas al Director de Informática y a otros miembros del Comité de Informática participantes en el proceso de elaboración del Plan Estratégico. Igualmente, realización de entrevistas a representantes de los usuarios con el fin de evaluar su grado de participación y sintonía con el contenido del Plan.

- Identificación y comprensión de los mecanismos existentes de seguimiento y actualización del Plan y de su relación con la evolución de la empresa.

10.2.2. Otros planes relacionados

Como se ha comentado más arriba, normalmente, deben existir otros planes informáticos, todos ellos nacidos al amparo del Plan Estratégico. Entre otros, los más habituales suelen ser:

- Plan operativo anual
- Plan de dirección tecnológica
- Plan de arquitectura de la información
- Plan de recuperación ante desastres

Algunos de ellos (Plan tecnológico, Plan de arquitectura) aparecen a veces integrados en el propio Plan Estratégico. En este capítulo, se tratarán sólo dos de estos planes, los más comunes y que, además, siempre tienen vida propia: Plan operativo y Plan de recuperación.

Plan operativo anual

El Plan operativo se establece al comienzo de cada ejercicio y es el que marca las pautas a seguir durante el mismo. Debe estar, obviamente, alineado con el Plan Estratégico. Asimismo, debe estar precedido de una recogida de necesidades de los usuarios.

El Plan operativo de Sistemas de Información describe las actividades a realizar durante el siguiente ejercicio natural. Entre otros aspectos, debe señalar los sistemas de información a desarrollar, los cambios tecnológicos previstos, los recursos y los plazos necesarios, etc.

El auditor deberá evaluar la existencia del Plan y su nivel de calidad. Deberá estudiar su alineamiento con el Plan Estratégico, su grado de atención a las necesidades de los usuarios, sus previsiones de los recursos necesarios para llevar a cabo el Plan, etc. Deberá analizar si los plazos descritos son realistas teniendo en cuenta, entre otras cosas, las experiencias anteriores en la empresa, etc.

Plan de recuperación ante desastres

Una instalación informática puede verse afectada por desastres de variada naturaleza: incendio, inundación, fallo de algún componente crítico de hardware, robo, sabotaje, acto de terrorismo, etc., que tengan como consecuencia inmediata la indisponibilidad de un servicio informático adecuado. La Dirección debe prever esta posibilidad y, por tanto, planificar para hacerle frente.

En otro capítulo de este libro se cubren los aspectos relativos a la auditoría de un Plan de recuperación ante desastres. Sin embargo, se quiere señalar aquí que dicho Plan es responsabilidad directa de la Dirección y no del responsable de la seguridad.

10.3. ORGANIZAR Y COORDINAR

El proceso de organizar sirve para estructurar los recursos, los flujos de información y los controles que permitan alcanzar los objetivos marcados durante la planificación.

10.3.1. Comité de Informática

Una de las acusaciones más comúnmente lanzadas contra la informática y los informáticos es la falta de comunicación y entendimiento que se establece entre el departamento de informática en la empresa y el resto de la misma. El Comité de Informática es el primer lugar de encuentro dentro de la empresa de los informáticos y sus usuarios: es el lugar en el que se debaten los grandes asuntos de la informática que afectan a toda la empresa y permite a los usuarios conocer las necesidades del conjunto de la organización –no sólo las de su área– y participar en la fijación de prioridades. Se evitan así acusaciones de favoritismo entre unas áreas y otras, en cuanto al trato recibido de informática, y, en definitiva, se atiende a la mejor utilización de los recursos informáticos, tradicionalmente escasos.

Si bien estrictamente el nombramiento, la fijación de funciones, etc. del Comité de Informática no son responsabilidades directas de la Dirección de Informática, sino de la Dirección General fundamentalmente, la Dirección de Informática se ha de convertir en el principal impulsor de la existencia de dicho Comité.

Aunque no existe regla fija, el Comité debería estar formado por pocas personas y presidido por el director más senior, dentro de la empresa, responsable en último término de las tecnologías de la información. El Director de Informática debería actuar como secretario del Comité y las grandes áreas usuarias deberían estar representadas al nivel de sus directores más senior. Asimismo, el director de Auditoría Interna debería ser miembro del Comité. Otras personas de la organización

también pueden integrarse en el Comité como miembros temporales cuando se traten asuntos de su incumbencia o de su especialidad.

Se ha escrito mucho sobre las funciones que debe realizar un Comité de Informática y parece existir un cierto consenso en, al menos, los siguientes aspectos:

- Aprobación del Plan Estratégico de Sistemas de Información.
- Aprobación de las grandes inversiones en tecnología de la información.
- Fijación de prioridades entre los grandes proyectos informáticos.
- Vehículo de discusión entre la Informática y sus usuarios.
- Vigila y realiza el seguimiento de la actividad del Departamento de Informática.

Guía de auditoría

Al tratarse del máximo órgano decisorio sobre el papel de las tecnologías de la información en la empresa, ninguna auditoría de la Dirección de Informática debería soslayar su revisión. El auditor deberá asegurar que el Comité de Informática existe y cumple su papel adecuadamente.

Para ello, deberá conocer, en primer lugar, las funciones encomendadas al Comité. En este punto, difieren las acciones concretas que el auditor deberá emprender ya que dependerán, en gran manera, del grado de Normalización imperante en la empresa. En unos casos, existirá una normativa interna explicando los objetivos, responsabilidades, componentes, etc. del Comité y en otros no existirá nada de eso y no habrá más que reuniones aperiódicas del mismo.

Entre las acciones a realizar, figuran:

- Lectura de la normativa interna, si la hubiera, para conocer las funciones que debería cumplir el Comité de Informática.
- Entrevistas a miembros destacados del Comité con el fin de conocer las funciones que en la práctica realiza dicho Comité.
- Entrevistas a los representantes de los usuarios, miembros del Comité, para conocer si entienden y están de acuerdo con su papel en el mismo.

Una vez establecida la existencia del Comité de Informática, habrá que evaluar la adecuación de las funciones que realiza. Para ello, el auditor, mediante un conjunto de entrevistas, lecturas de documentación interna del Comité, etc., deberá establecer un juicio sobre la validez, adecuación, etc. de las actuaciones del Comité. Uno de los

aspectos, fundamentales que deberá revisar es el que hace referencia a la presencia y participación efectiva de las áreas usuarias.

Entre las acciones a realizar, figuran:

Lectura de las actas del Comité y entrevistas a los miembros del mismo, con especial incidencia en los representantes de los usuarios para comprobar que:

- El Comité cumple efectivamente con las funciones enunciadas más arriba.
- Los acuerdos son tomados correctamente y los puntos de vista de los representantes de los usuarios son tenidos en cuenta.

10.3.2. Posición del Departamento de Informática en la empresa

El segundo aspecto importante a tener en cuenta a la hora de evaluar el papel de la informática en la empresa, es la ubicación del Departamento de Informática en la estructura organizativa general de la misma. El Departamento debería estar suficientemente alto en la jerarquía y contar con masa crítica suficiente para disponer de autoridad e independencia frente a los departamentos usuarios.

Tradicionalmente, la informatización en las empresas comenzó por el departamento financiero o de administración y, por tanto, el esquema tradicional era encontrar al departamento de informática integrado dentro del financiero o administrativo. Hoy en día, la informática da soporte a un conjunto mucho mayor de áreas empresariales y, por ello, cada vez es más habitual encontrar a departamentos de informática dependiendo directamente de Dirección General. Incluso, en las grandes organizaciones, el Director de Informática es miembro de derecho del Comité de Dirección u órgano semejante. Siempre que el departamento de informática esté integrado en algún departamento usuario, pueden surgir dudas razonables sobre su ecuanimidad a la hora de atender las peticiones del resto de departamentos de la empresa.

Una vez más, estrictamente hablando, la posición del Departamento de Informática no incumbe su Dirección sino a otros estamentos empresariales, probablemente, la Dirección General. Sin embargo, se trae a colación en este capítulo, porque el auditor debe evaluar si las necesidades de los diferentes departamentos de la empresa son tratadas equitativamente por Informática y no existe un sesgo demasiado alto hacia un departamento de la misma. Si esto último ocurriera, una de las primeras razones para ello puede ser la ubicación incorrecta de dicho Departamento.

Guía de auditoría

El auditor deberá revisar el emplazamiento organizativo del Departamento de Informática y evaluar su independencia frente a departamentos usuarios. Para este proceso, será muy útil realizar entrevistas con el Director de Informática y directores de algunos departamentos usuarios para conocer su percepción sobre el grado de independencia y atención del Departamento de Informática.

10.3.3. Descripción de funciones y responsabilidades del Departamento de Informática. Segregación de funciones

Es necesario que las grandes unidades organizativas dentro del Departamento de Informática tengan sus funciones descritas y sus responsabilidades claramente delimitadas y documentadas. Igualmente, es necesario que este conocimiento se extienda a todo el personal perteneciente a Informática: todos ellos deben conocer sus funciones y responsabilidades en relación con los sistemas de información. Y todo ello es una labor que compete, en gran medida, a la Dirección de Informática.

Por otro lado, es de todo punto esencial para tener un entorno controlado que exista una división de funciones y responsabilidades. La filosofía básica que debe orientar esta separación de papeles es impedir que un solo individuo pueda trastornar un proceso crítico. Además, se debería asegurar que el personal de Informática actúa únicamente dentro de la descripción de las funciones existente para su puesto de trabajo concreto.

En particular, se debería asegurar la segregación entre las funciones de desarrollo de sistemas de información, la de producción o explotación y los departamentos de usuarios. Además, la función de administración de la seguridad debería estar claramente separada de la de producción.

Aseguramiento de la Calidad

La calidad de los servicios ofrecidos por el Departamento de Informática debe estar asegurada mediante el establecimiento de una función organizativa de Aseguramiento de la Calidad. Cada vez más hoy en día, se asiste, en las organizaciones informáticas evolucionadas, a la aparición de esta función de control de calidad de los servicios informáticos, a imagen y semejanza de las organizaciones en el mundo industrial. Esta función de control ha de ser independiente de la actividad diaria del departamento y ha de depender directamente de la Dirección de Informática.

Es muy importante que esta función, de relativa nueva aparición en el mundo de las organizaciones informáticas, tenga el total respaldo de la Dirección y sea percibido así por el resto del Departamento.

Guía de auditoría

No es propósito de este capítulo describir las funciones de un departamento de informática. Ello se describe en otros capítulos de este libro, además de que existe una amplísima bibliografía sobre la materia. El aspecto fundamental que queremos resaltar aquí es que el auditor deberá comprobar que las descripciones están documentadas y son actuales y que las unidades organizativas informáticas las comprenden y desarrollan su labor de acuerdo a las mismas.

Entre las tareas que el auditor podrá realizar, figuran:

- Examen del organigrama del Departamento de Informática e identificación de las grandes unidades organizativas.

- Revisión de la documentación existente para conocer la descripción de las funciones y responsabilidades.

- Realización de entrevistas a los directores de cada una de las grandes unidades organizativas para determinar su conocimiento de las responsabilidades de su unidad y que éstas responden a las descripciones existentes en la documentación correspondiente.

- Examen de las descripciones de las funciones para evaluar si existe adecuada segregación de funciones, incluyendo la separación entre desarrollo de sistemas de información, producción y departamentos usuarios. Igualmente, será menester evaluar la independencia de la función de seguridad.

- Observación de las actividades del personal del Departamento para analizar, en la práctica, las funciones realizadas, la segregación entre las mismas y el grado de cumplimiento con la documentación analizada.

Aseguramiento de la Calidad

El auditor deberá evaluar la independencia de la función frente al resto de áreas operativas del Departamento de Informática, su dotación de recursos humanos, la experiencia de los mismos, la existencia de métodos y procedimientos formales de

actuación, las posibilidades reales de realizar su trabajo, el contenido de los informes elaborados por la función, etc.

Entre las acciones a llevar a cabo, se pueden considerar:

- Conocimiento de la posición de la Función en el organigrama del Departamento de Informática.

- Análisis del grado de cumplimiento de las actividades del Departamento en relación con las políticas, estándares y procedimientos existentes tanto generales del Departamento como específicos de sus funciones organizativas. De particular importancia es el grado de cumplimiento de la metodología del ciclo de vida de los sistemas de información, de los procedimientos que gobiernan la explotación del computador y de la investigación de la calidad de los datos que se envían a los usuarios.

- Revisión de algunos informes emitidos por la Función con el fin de evaluar si su estructura y contenido son adecuados. Analizar la existencia de acciones de seguimiento basadas en dichos informes.

10.3.4. Estándares de funcionamiento y procedimientos. Descripción de los puestos de trabajo

Deben existir estándares de funcionamiento y procedimientos que gobiernen la actividad del Departamento de Informática por un lado, y sus relaciones con los departamentos usuarios por otro. Estos estándares son el vehículo ideal para transmitir al personal de Informática la filosofía, mentalidad y actitud hacia los controles necesarios con la finalidad de crear y mantener un entorno controlado para la vida de los sistemas de información de la empresa.

De particular importancia son los aspectos relacionados con la adquisición de equipos o material para el Departamento, con el diseño y el desarrollo/modificación de sistemas de información y con la producción o explotación.

Además, dichos estándares y procedimientos deberían estar documentados, actualizados y ser comunicados adecuadamente a todos los departamentos afectados. La Dirección de Informática debe promover la adopción de estándares y procedimientos y dar ejemplo de su uso.

Por otro lado, deben existir documentadas descripciones de los puestos de trabajo dentro de Informática delimitando claramente la autoridad y responsabilidad en cada

caso. Las descripciones deberían incluir los conocimientos técnicos y/o experiencia necesarios para cada puesto de trabajo.

Guía de auditoría

El auditor deberá evaluar la existencia de estándares de funcionamiento y procedimientos y descripciones de puestos de trabajo adecuados y actualizados.

Entre las acciones a realizar, se pueden citar:

- Evaluación del proceso por el que los estándares, procedimientos y puestos de trabajo son desarrollados, aprobados, distribuidos y actualizados.
- Revisión de los estándares y procedimientos existentes para evaluar si transmiten y promueven una filosofía adecuada de control. Evaluación de su adecuación, grado de actualización, y nivel de cobertura de las actividades informáticas y de las relaciones con los departamentos usuarios.
- Revisión de las descripciones de los puestos de trabajo para evaluar si reflejan las actividades realizadas en la práctica.

10.3.5. Gestión de recursos humanos: selección, evaluación del desempeño, formación, promoción, finalización

La gestión de los recursos humanos es uno de los elementos críticos en la estructura general informática. La calidad de los recursos humanos influye directamente en localidad de los sistemas de información producidos, mantenidos y operados por el Departamento de Informática. Además, parte de los recursos humanos necesarios en una instalación informática son grandes expertos técnicos. Seleccionarlos, mantenerlos y motivarlos adecuadamente puede ser crucial para la buena marcha de la informática y su papel en la empresa.

Guía de auditoría

Entre otros aspectos, el auditor deberá evaluar que:

- La selección de personal se basa en criterios objetivos y tiene en cuenta la formación, experiencia y niveles de responsabilidad anteriores.

- El rendimiento de cada empleado se evalúa regularmente en base a estándares establecidos y responsabilidades específicas del puesto de trabajo.

- Existen procesos para determinar las necesidades de formación de los empleados en base a su experiencia, puesto de trabajo, responsabilidad y desarrollo futuro personal y tecnológico de la instalación. Se planifica la cobertura ordenada de estas necesidades y se lleva a la práctica.

- Existen procesos para la promoción del personal que tienen en cuenta su desempeño profesional.

- Existen controles que tienden a asegurar que el cambio de puesto de trabajo y la finalización de los contratos laborales no afectan a los controles internos y a la seguridad informática.

Además, el auditor deberá evaluar que todos los aspectos anteriores están en línea con las políticas y procedimientos de la empresa.

Entre las acciones a realizar, se pueden citar:

- Conocimiento y evaluación de los procesos utilizados para cubrir vacantes en el Departamento de Informática, bien sea por promoción interna, búsqueda directa de personal externo, utilización de empresas de selección de personal o de trabajo temporal.

- Análisis de las cifras de rotación de personal, niveles de absentismo laboral y estadísticas de proyectos terminados fuera de presupuesto y de plazo. Si los números son anormales (muy altos), podrían constituir una señal de falta de liderazgo por parte de la Dirección de Informática y/o de motivación por parte del personal.

- Realización de entrevistas a personal del Departamento para determinar su conocimiento de las responsabilidades asociadas a su puesto de trabajo y de los estándares de rendimiento, y analizar si los resultados de sus evaluaciones de desempeño han sido comunicadas de una manera acorde con los procedimientos establecidos.

- Revisión del calendario de cursos, descripciones de los mismos, métodos y técnicas de enseñanza, para determinar que los cursos son consistentes con los conocimientos, experiencia, responsabilidades, etc. asignadas al personal y con la estrategia tecnológica marcada para los sistemas de información de la empresa.

- Revisión de los procedimientos para la finalización de contratos. Evaluar si dichos procedimientos prevén que los identificadores de usuario, passwords y prevén otros dispositivos necesarios para tener acceso a los locales y sistemas

informáticos son cancelados, devueltos, etc., con efectividad inmediata tras la finalización del contrato de un empleado.

10.3.6. Comunicación

Es necesario que exista una comunicación efectiva y eficiente entre la Dirección de Informática y el resto del personal del Departamento. Entre los aspectos que es importante comunicar se encuentran: actitud positiva hacia los controles, integridad, ética, cumplimiento de la normativa interna –entre otras, la de seguridad informática–, compromiso con la calidad, etc.

Guía de auditoría

El auditor deberá evaluar las características de la comunicación entre la Dirección y el personal de Informática. Para ello se podrá servir de tareas formales como las descritas hasta ahora y de otras, por ejemplo, a través de entrevistas informales con el personal del Departamento.

10.3.7. Gestión económica

Este apartado de las responsabilidades de la Dirección de Informática tiene varias facetas: presupuestación, adquisición de bienes y servicios y medida y reparto de costes.

10.3.7.1. Presupuestación

Como todo departamento de la empresa, el de Informática debe tener un presupuesto económico, normalmente en base anual. Los criterios sobre cuáles deben ser los componentes del mismo varían grandemente. Un ejemplo típico son los costes de las comunicaciones: en unos casos es el propio Departamento quien corre con ellos y, en otros casos, puede ocurrir que la política de la empresa indique que sean pagados por los departamentos usuarios. En otro ejemplo, también puede ocurrir que los terminales (pantallas e impresoras) sean costeados por los usuarios en vez de serlo por Informática. Sea cual sea la política seguida en la empresa, el Departamento de Informática debe seguirla para elaborar su presupuesto anual.

No vamos a entrar aquí en los diversos métodos existentes de presupuestación, pero el auditor deberá juzgar si son apropiados. Lo que sí debería darse en todo proceso de presupuestación de un Departamento de Informática es una previa petición de necesidades a los departamentos usuarios. Adicionalmente, el Departamento tendrá

sus propias necesidades: cambio o ampliación del computador o de los discos, instalación de un robot manejador de cartuchos, de una unidad de comunicaciones, etc. que se deberán integrar en el presupuesto. Lo más lógico es elaborar al mismo tiempo el presupuesto económico y el Plan operativo anual.

Guía de auditoría

El auditor deberá constatar la existencia de un presupuesto económico, de un proceso para elaborarlo –que incluya consideraciones de los usuarios– y aprobarlo, y que dicho proceso está en línea con las políticas y procedimientos de la empresa y con los planes estratégico y operativo del propio Departamento.

10.3.7.2. Adquisición de bienes y servicios

Los procedimientos que el Departamento de Informática siga para adquirir los bienes y servicios descritos en su plan operativo anual y/o que se demuestren necesarios a lo largo del ejercicio han de estar documentados y alineados con los procedimientos de compras del resto de la empresa. Aquí, la variedad es infinita, con lo que es imposible dar reglas fijas.

Guía de auditoría

Una auditoría de esta área no debe diferenciarse de una auditoría tradicional del proceso de compras de cualquier otra área de la empresa, con lo que el auditor deberá seguir básicamente las directrices y programas de trabajo de auditoría elaborados para este proceso.

10.3.7.3. Medida y reparto de costes

La Dirección de Informática debe en todo momento gestionar los costes asociados con la utilización de los recursos informáticos: humanos y tecnológicos. Y ello, obviamente, exige medirlos.

Un aspecto muy relacionado es el reparto de los costes del Departamento entre los usuarios. Esta medida no está implantada en todas las empresas y, además, tiene sus ventajas e inconvenientes que, también, se encuentran fuera del alcance de este libro. Normalmente, la existencia o ausencia de un sistema de este tipo suele estar muy asociada a la propia cultura de la empresa. En cualquier caso, es cierto que, de estar presente, se da en general, con mayor frecuencia, en grandes organizaciones con

grandes centros de proceso de datos centralizados. Es raro encontrar un sistema de reparto de costes en centros informáticos de departamentos.

Guía de auditoría

El reparto de costes suele ser un tema delicado. En realidad, el asunto espinoso suele ser el llamado precio de transferencia, o sea el coste interno que el Departamento de Informática repercute a los departamentos usuarios por los servicios que les presta.

El auditor deberá evaluar la conveniencia de que exista o no un sistema de reparto de costes informáticos y de que éste sea justo, incluya los conceptos adecuados y de que el precio de transferencia aplicado esté en línea o por debajo del disponible en el mercado.

Entre las acciones a llevar a cabo, se pueden mencionar:

- Realización de entrevistas a la dirección de los departamentos usuarios para evaluar su grado de comprensión de los componentes de coste utilizados en la fórmula de cálculo del precio de transferencia.

- Análisis de los componentes y criterios con los que está calculado el precio de transferencia para evaluar su ecuanimidad y consistencia, y acudir al mercado externo y a ofertas de centros de proceso de datos independientes para compararlas con dichos costes internos.

- Conocimiento de los diversos sistemas existentes en el Departamento para recoger y registrar la actividad del mismo (consumo de recursos de máquina, número de líneas impresas, horas de programación, de *help-desk,* etc.), para procesarla y obtener la información de costes y para presentarla de una manera apropiada.

10.3.8. Seguros

La Dirección de Informática debe tomar las medidas necesarias con el fin de tener suficiente cobertura de seguros para los sistemas informáticos. Aquí se incluyen no sólo las coberturas más tradicionales como la de los equipos (el hardware) o la de infidelidad de los empleados, sino también otro tipo de coberturas normalmente más asociadas a la repentina interrupción del servicio informático por causa de algún desastre. Estas coberturas amparan riesgos tales como la posible pérdida de negocio derivada de dicha interrupción, los costes asociados al hecho de tener que ofrecer servicio informático desde un lugar alternativo por no estar disponible el sitio primario

los costes asociados a la regeneración de datos por pérdida o inutilización de los datos originales, etc.

Guía de auditoría

El auditor deberá estudiar las pólizas de seguros y evaluar la cobertura existente, analizando si la empresa está suficientemente cubierta o existen huecos en dicha cobertura. Por ejemplo, algunas pólizas sólo cubren el reemplazo del equipo, pero no los otros costes mencionados, etc.

10.4. CONTROLAR

La tarea de *dirigir* no puede considerarse completa sin esta faceta que forma parte indisoluble de tal responsabilidad.

10.4.1. Control y seguimiento

Un aspecto común a todo lo que se ha dicho hasta el momento es la obligación de la Dirección de controlar y efectuar un seguimiento permanente de la distinta actividad del Departamento. Se ha de vigilar el desarrollo de los planes estratégico y operativo y de los proyectos que los desarrollan, la ejecución del presupuesto, la evolución de la cartera de peticiones de usuario pendientes, la evolución de los costes, los planes de formación, la evolución de la carga del computador y de los otros recursos (espacio en disco, comunicaciones, capacidad de las impresoras...), etc.

En esta labor, es muy conveniente que existan estándares de rendimiento con los que comparar las diversas tareas. Son aplicables a las diversas facetas de la actividad del Departamento: consumo de recursos del equipo, desarrollo, operaciones, etc.

Guía de auditoría

Entre las acciones a realizar, se pueden mencionar:

- Conocimiento y análisis de los procesos existentes en el Departamento para llevar a cabo el seguimiento y control. Evaluación de la periodicidad de los mismos. Analizar igualmente los procesos de represupuestación.

- Revisión de planes, proyectos, presupuestos de años anteriores y del actual para comprobar que son estudiados, que se analizan las desviaciones y que se toman las medidas correctoras necesarias.

10.4.2. Cumplimiento de la normativa legal

La Dirección de Informática debe controlar que la realización de sus actividades se lleva a cabo dentro del respeto a la normativa legal aplicable. En particular, se consideran fundamentales los relativos a la seguridad e higiene en el trabajo, normativa laboral y sindical, protección de datos personales, propiedad intelectual del software, requisitos definidos en la cobertura de seguros, contratos de comercio electrónico, transmisión de datos por líneas de comunicaciones, así como normativa emitida por órganos reguladores sectoriales.

Asimismo, deben existir procedimientos para vigilar y determinar permanentemente la legislación aplicable.

Guía de auditoría

El auditor deberá evaluar si la mencionada normativa aplicable se cumple.

Para ello, deberá, en primer lugar, entrevistarse con la Asesoría Jurídica de la empresa, la Dirección de Recursos Humanos y la Dirección de Informática con el fin de conocer dicha normativa.

A continuación, evaluará el cumplimiento de las normas, en particular en los aspectos más críticos mencionados más arriba. Si el auditor no es un técnico en los distintos aspectos legales, deberá buscar asesoramiento adecuado interno a la empresa o externo.

10.5. RESUMEN

La auditoría de la Dirección de Informática es una tarea difícil. Sin embargo, la contribución que dicha Dirección de Informática realiza (o debe realizar) al ambiente de control de las operaciones informáticas de una empresa es esencial. Desde un punto de vista de auditoría, la calidad del marco de controles impulsado e inspirado por la Dirección de Informática tiene una gran influencia sobre el probable comportamiento de los sistemas de información. Por parte del auditor, son más necesarias las capacidades, de evaluar la *gestión* que las capacidades técnicas muy profundas.

10.6. LECTURAS RECOMENDADAS

EDP Auditing, Conceptual Foundations and Practice. Ron Weber. McGraw-Hill, 1993.

Control Objectives for Information and Related Technology. Information Systems and Control Foundation, 1996.

Control Objectives. EDP Auditors Association, 1992.

Systems Auditability and Control. The Institute of Internal Auditors Research Foundation, 1991.

10.7. CUESTIONES DE REPASO

1. Descríbanse las actividades a realizar por un auditor para evaluar un plan estratégico de sistemas de información.

2. Descríbanse las funciones de un comité de informática. Elabórese una lista con las funciones empresariales que deberían estar representadas en dicho comité. ¿Qué objetivo tiene para los usuarios su presencia en el comité?

3. Descríbanse las ventajas de tener procedimientos. Elabórese un guión de lo que podrían ser procedimientos de: a) diseño de sistemas b) programación.

4. ¿Qué evidencias deberá buscar el auditor para poder evaluar si las necesidades de los usuarios son tenidas en cuenta adecuadamente?

5. Identifíquense las actividades incompatibles desde un punto de vista de control en un departamento de informática. Razónese.

6. ¿Qué ventajas de control aporta la existencia de la función de aseguramiento de la calidad?

7. Descríbanse los objetivos de control a ser evaluados por el auditor en el apartado de gestión de recursos humanos.

8. ¿Qué tareas debe realizar un auditor para evaluar el plan de formación del departamento de informática? ¿Cómo puede juzgar si dicho plan es acorde con los objetivos de la empresa?

9. Relaciónense las actividades a realizar por un auditor para la evaluación del precio de transferencia de reparto de costes entre el departamento de informática y los usuarios.

10. ¿Cuáles son las áreas legales cuyo cumplimiento es el más importante de auditar?